COMP4127/COMP7850

Information Security

Course Introduction

Teaching Staffs

Instructor

- Dr. Kevin Wang King Hang
  - Office: RRS712
  - Tel: 7704
  - Email: kevinw@comp.hkbu.edu.hk

Teaching Assistant

- Mr. ZOU, Bohao; csbhzou@comp.hkbu.edu.hk (Tuesday 3:30-4:30, DLB625)
- Mr. HE, Fengliang; csflhe@comp.hkbu.edu.hk (Tuesday 6:30-7:30, DLB625)

Lectures

- Co-located Course:
  - COMP4127: Information Security/COMP7850: Information Security Management
- Time and Venue:
  - **Thursday 15:30 - 18:20 (FSC801CD)**
  - The last hour is always an activity.
- Course websites:
  - Moodle
  - **Piazza** (will receive Piazza invitation)

Security - from COMP7990

香港浸會大學
HONG KONG BAPTIST UNIVERSITY

Data Breach

- A major European airline suffered a GDPR reportable breach. The breach was reportedly caused by payment application security vulnerabilities exploited by attackers, who harvested more than 400,000 customer payment records. The airline was fined 20 million pounds as a result by the privacy regulator.

British Airways fined £20m over data breach

16 October 2020

British Airways has been fined £20m ($26m) by the Information Commissioner's Office (ICO) for a data breach which affected more than 400,000 customers

Security - from COMP7990

Communication Hacked

- Information security plays an important role in modern war

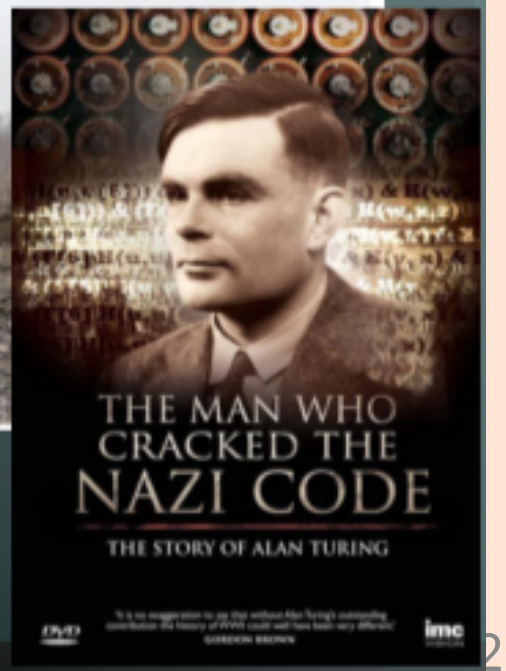


image ref: imc vision; Washington post

Security - from COMP7990

Service taken down

- Network attacks may cause web service down and company/organization will not be able to continue their business.
- On Feb. 28, 2018, GitHub, a platform for software developers, was hit with a DDoS attack that clocked in at 1.35 terabits per second and lasted for roughly 20 minutes.

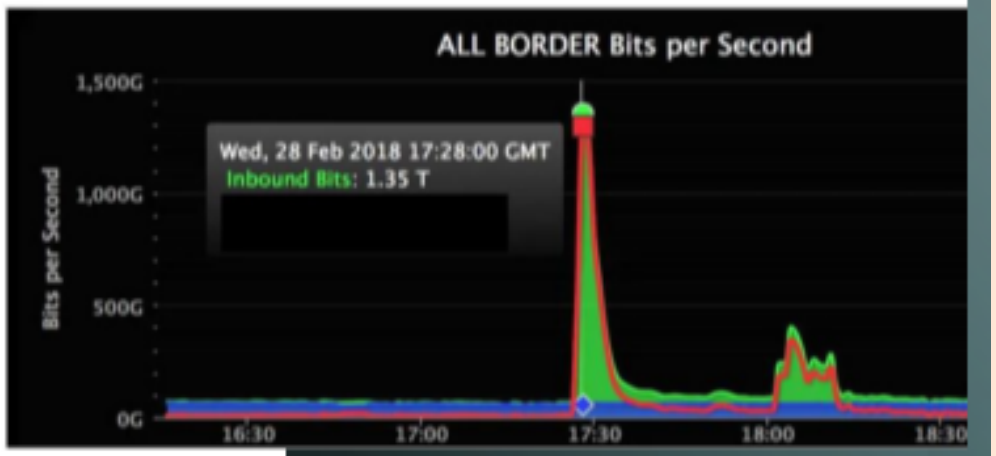
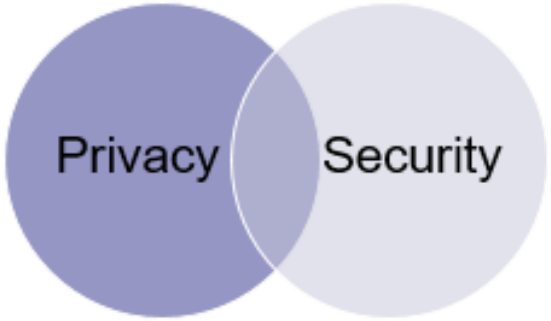


image ref: https://thehackernews.com/

Security - from COMP7990

Data Security and Privacy

- Data Security
  - An umbrella term for ensuring data's **confidentiality**, **integrity**, and **availability**.
    - Storing company documents
    - Make sure browser connected to a legit website
    - Prevent networks jamming attacks
- Data Privacy
  - Addressing the collection, access, usage, storage of (private/public) data of an individual.
  - Examples of invading privacy:
    - Transfer all customer's phone number to a marketing company.
    - Print all IG photos of a classmate and stick them on the classroom wall.
    - Leak customer's credit card info.

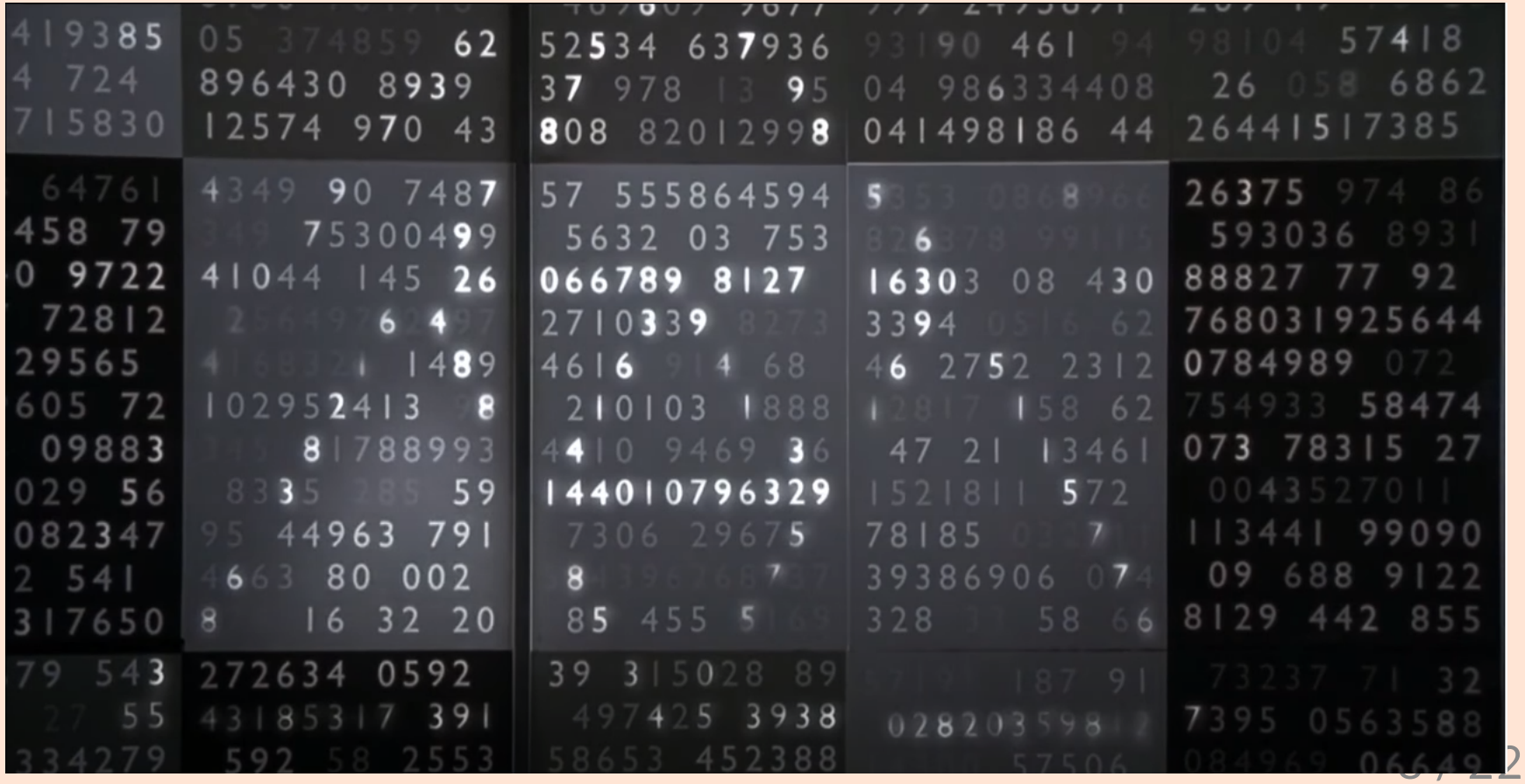


What is (not) Security?

What do you expect to learn from this course?

- Would a **password** get all things done?

Click to play ➡️



ref: extract from the movie: A Beautiful Mind

Security is...

(img credit: https://www.harrypotterfanzone.com/defence-against-the-dark-arts-teachers/)

Examples of How-To Problems in security:

- How to **Securely deliver a message^**
- How to **Correctly identify the person**
- How to **Allow only intended users to access certain resources**
- How to **Vote**
- How to **Setup a fair exam**
- ...

Furthermore

Securely deliver a message

- Others don't knows the message was delivered
- Ensures the message has been successfully delivered
- Ensures no others has read the message
- Others can't read the message
- Ensures the message is delivered from the one you trust

Think of a solution...

Imagine you are a TA, holding a closed-book exam about constitution law that requires a heavy work of memorizing. To your understanding, your students will cheat. What will you do to minimize the risk of exam cheating?

Think of a solution #2

The palace is looking for a girl who can fit her foot into a glass shoe. Whoever can fit her foot into the shoe might be the next princess. This is a golden opportunity. What will you do to make yourself be the next princess?

Security is Hot in the Job market!

香港浸會大學
HONG KONG BAPTIST UNIVERSITY

Internet R&D

Front-end - Permanent

Job Title	Low	Median	High
Head of Front-end (¥ Per Annum)	¥800000+Stock Options	¥1200000+Stock Options	¥1500000+Stock Options
Front-end Manager (¥ Per Month)	¥40,000	¥50,000	¥60,000
Front-end Architect (¥ Per Month)	¥30,000	¥40,000	¥50,000
Front-end Developer (¥ Per Month)	¥20,000	¥30,000	¥40,000
Head of Mobile Development (¥ Per Annum)	¥700000+Stock Options	¥900000+Stock Options	¥1200000+Stock Options
iOS Architect (¥ Per Month)	¥35,000	¥40,000	¥50,000
iOS Developer (¥ Per Month)	¥25,000	¥30,000	¥35,000
Android Architect (¥ Per Month)	¥35,000	¥40,000	¥50,000
Android Developer (¥ Per Month)	¥25,000	¥30,000	¥35,000

Corporate IT

Information Security - Permanent

Job Title	Low	Median	High
CISO (¥ Per Month)	¥60,000	¥80,000	¥100,000
Application Security (¥ Per Month)	¥40,000	¥50,000	¥60,000
Network Security (¥ Per Month)	¥30,000	¥40,000	¥50,000
Data Privacy (¥ Per Month)	¥50,000	¥60,000	¥80,000

ref: [The Morgan McKinley 2022 Salary Guide for IT professionals in China]

Tentative Assessment Scheme

- Continuous Assessment (50%)
  - Midterm: (15%)
  - CTF and write up: (18%), group participation is expected.
  - In-class participation: (2%)
  - Others (15%)
    - UG: Individual Coding Project.
    - PG: Group Case Study + Individual Assignment
- Examination (50%)
  - Covers all topics of the course.
  - Exam date: TBA

Academic Honesty

The University staunchly upholds the principles of academic integrity. As one part of HKBU's effort to prevent plagiarism, the software Turnitin is used to compare all assignments against multiple sources whenever appropriate. A report on each assignment is generated that includes a percentage similarity and links to specific similar sources. Turnitin does not conclusively prove whether or not an assignment is plagiarized – the faculty will make this determination.

Academic Honesty

To make sure you do not commit any kind of academic dishonesty/plagiarism:

- Do not copy any assessment from others
- Do not upload your assessment to any public repository online
- Do not send your assessment to your friends
- Do you copy any work from other website without properly citation.
- If you have doubt, consult your instructor for explicit clarification.

Penalty for Plagiarism

http://ar.hkbu.edu.hk/curr/avoid_plagiarism/
http://ar.hkbu.edu.hk/file/22

Learning outcomes

Students will learn the fundamental concepts of cryptography; the principles and practices of information security at different levels: bit level, message level, protocol level, system and network level, organization level and society level. They will also learn the current topics, including blockchain.

Schedule

Lecture	Content	Activities
1	Intro and Classic Crypto	CTF-0
2	Symmetric and Public Key	
3	Hash/MAC/DS	**CTF-1** (3%)
4	Authentication	**CTF-2** (3%)
5	IPSec/TLS and VPN	**CTF-3** (3%)
6	Network and System Security	**CTF-4** (3%)
7	Wi-Fi Security	**CTF-5** (3%)
8	Web Security	**CTF-6** (3%)
9-10	Security Management	**Midterm** (15%)
11	Blockchain	
12	Blockchain2	Project Due
13	Summary	Q & A

CTF

- CTF = **C**apture **T**he **F**lag. A CTF game requires the participants to solve a challenge and recover a flag.
  - A flag is a string of characters like CTF_{1ST_FLAG}.
- Students are encourage to form a group with no more than 3 students to solve the challenge. In the activity time, members of a group will discuss among themselves and attempt to solve the CTF challenge. Most of the CTF are not straight forward. Don't worry, hint will be given to you for most of the time.
- At the end all of you will need to submit a **write-up** (according to the template) as an **individual** work.

Requirement of the course

- A computer that has Docker installed.
- Lecture time participation.
- Be an active learner.
  - Participate your learning on Piazza.

Textbook & Reference

- William Stallings, Network Security Essentials: Applications and Standards. Fourth Edition, 2011 [or newer]
- Michael E. Whitman and Herbert J. Mattord, Management of Information Security. Sixth Edition, 2018 [or newer]